

MANDIANT / GOOGLE CLOUD THREAT INTELLIGENCE

Special Intelligence Report: APT29 Cloud Token Theft and Deep Persistence

Published: January 2024 | Author: Mandiant Advanced Practices | TLP:CLEAR

EXECUTIVE BRIEFING

Mandiant has tracked unprecedented espionage campaigns orchestrated by **APT29** (also known as Midnight Blizzard, Cozy Bear, NOBELIUM), a premier cyber espionage group affiliated with the Russian Foreign Intelligence Service (SVR). Recent investigations uncover advanced techniques targeting Microsoft 365 and Entra ID cloud tenants. By compromising non-production legacy testing accounts lacking multi-factor authentication, the adversary granted illicit application permissions and minted custom OAuth bearer tokens to achieve persistent, silent access to diplomatic and defense communications.

MALWARE IMPLANTS & PERSISTENCE MECHANISMS

In hybrid cloud environments, APT29 deployed specialized backdoor utilities, notably MagicWeb and FoggyWeb, to subvert Active Directory Federation Services (AD FS) and forge authentication SAML tokens. On corporate Windows workstations, APT29 configured persistence via scheduled tasks and the following registry run keys:

- HKCU\Software\Microsoft\Windows\CurrentVersion\Run\EdgeUpdater

The actors also weaponized **CVE-2023-38831** (WinRAR code execution vulnerability) and **CVE-2024-21413** (Microsoft Outlook RCE) to deliver Cobalt Strike and custom loader payloads to foreign ministry personnel.

INDICATORS OF COMPROMISE (IoCs)

Type	Defanged Indicator	Description	Confidence
Domain	auth-azure-sync[.]com	Fake Entra ID Login / Token C2	High
Domain	login-microsoftonline-verify[.]net	Credential Harvesting Endpoint	High
Domain	graph-api-telemetry[.]org	Data Exfiltration Relay	High
IPv4	185[.]220[.]101[.]5	AD FS Token Extraction C2	High
IPv4	45[.]154[.]255[.]89	Cobalt Strike Team Server	High
URL	hxxps://auth-azure-sync[.]com/oauth/token/v2	Malicious Token Endpoint	High
URL	hxxp://login-microsoftonline-verify[.]net/payload/loader.bin	Stage-2 Dropper URL	High
SHA-256	a3c1031d77a83d47a4697ff3f81e3a2c416805bb2f61e8ec5d91361b78292851	MagicWeb AD FS DLL Implant	High
SHA-256	d54f5905186ff946d8c8e88e895744883bb379b329ebc0e9565e381b16d96570	FoggyWeb Loader Binary	High
Registry	HKCU\Software\Microsoft\Windows\CurrentVersion\Run\EdgeUpdater	Persistence Key for Stage 1	High
CVE	CVE-2023-38831	WinRAR Remote Code Execution	Critical
CVE	CVE-2024-21413	Microsoft Outlook NTLM Leak RCE	Critical
Email	admin[@]embassy-support-desk[.]org	Spear-phishing Lure Sender	High